TIDEWAY · TOPIC E

# Tideway

Approval-gated cash-flow rescue for small businesses

- FinTechathon 2026 · International Track · Topic E: SME Finance Copilot
- An agent that can read, analyse and propose, but cannot approve or execute.
- Synthetic sandbox: no real money, bank, lender or customer.

# The moment that matters

Payroll is days away and cash is short

- Owners need bounded choices, not another dashboard.
- Which bill can wait? Who can pay early? What if customers pay late?
- An AI that answers must never be able to move money on its own.

# A concrete case: Shapla Services (synthetic, BDT)

Exact numbers, linked to source records

- Opening cash 120,000 · payroll 80,000 · supplier bill 70,000 · confirmed receivable 20,000
- Scheduled minimum cash: –10,000 on 31 Oct 2026; reserve floor 20,000
- Reserve shortfall: 30,000. Customer habits make it worse.

# See the risk

Customer profiles and a seeded Monte Carlo

- Credibility-weighted payment profiles: own history n/(n+5), rest from the business average
- Three scenarios (scheduled, likely, stress) plus a 14-day look-ahead
- 1,000 seeded runs: probability of breaching the reserve; same records, same answer

# Plan the rescue

An exact, risk-aware optimiser

- Searches supplier deferrals, early-payment discounts and zero-cash reminders
- Keeps bundles that hold the reserve every day and keep payroll funded
- Cheapest bundle within the risk target; discounts priced as APR (2%/20 days ≈ 37%)
- Financing: labelled MOCK comparison only, never executable

# Negotiate, then decide

Simulated counterparties; human approval; signed mandate

- Counterparties accept, counter or reject; a counter is a new proposal; a refusal re-plans
- Maker-checker with PIN step-up; two people and a typed amount above the threshold
- HMAC-signed mandate, modelled on AP2: scoped, expiring, tamper-evident
- Idempotent execution with before/after state hashes and read-back

# Security: the model is not the weak link

Enforcement lives outside the model

- No approve or execute tool; pseudonymised names; record text never sent
- Hidden Unicode stripped; injection quarantined; changed-account and look-alike payee blocks
- Kill switch, circuit breaker, separation of duties, owner-only callback verification
- Hash-chained audit with witness checkpoint and tamper drill

# Evidence

30 of 30 sandbox cases pass

- 5 task cases + 25 attack cases, assuming a hijacked model and a rubber-stamp human
- Mapped to OWASP LLM and Agentic IDs; 15 further unit and HTTP tests
- Reproducible: python3 -m tideway.selftest · scripts/evaluate.py
- Evidence for these cases only, not proof of security

# Honest limits and next steps

What we have not done

- Synthetic data, simulated counterparties, demo-grade PINs and keys
- No live-LLM measurement, no user study, no external penetration test
- Next: baseline comparison, consented SME interviews, a real rail adapter behind the same mandate
- ISO 20022 pain.001 draft shows the adapter boundary; it is never sent